REGRAS DE NEGÓCIO - AUTENTICAÇÃO

O requisito RF018 explica que o administrador deve entrar no sistema com e-mail e senha, mas o documento original não detalha o que acontece quando a senha está errada, quando a sessão termina ou quando há várias tentativas de acesso. Para preencher essa lacuna, foram organizadas as regras abaixo como proposta para avaliação da equipe.

Código	Regra proposta
RN011 — Validação das credenciais	O sistema deve conferir o e-mail e a senha informados. O acesso ao painel só deve ser liberado quando os dados corresponderem a uma conta administrativa válida.
RN012 — Dados incorretos	Se o e-mail ou a senha não forem reconhecidos, o acesso deve ser negado. A mensagem apresentada deve ser genérica, sem indicar qual informação está incorreta.
RN013 — Tentativas consecutivas	Depois de cinco tentativas seguidas sem sucesso, o sistema deve bloquear temporariamente novas tentativas por 15 minutos. A equipe ainda precisa definir como o contador será reiniciado.
RN014 — Expiração da sessão	A sessão deve terminar depois de 30 minutos sem atividade. Quando isso acontecer, o acesso às áreas protegidas deve ser encerrado e o administrador deve voltar à tela de login.
RN015 — Sair do sistema	Quando o administrador selecionar a opção de sair, a sessão deve ser encerrada. Para acessar novamente as áreas protegidas, será necessário fazer login.
RN016 — Proteção das rotas	O sistema deve verificar se o administrador está autenticado tanto nas rotas do frontend quanto nos endpoints protegidos da API. Digitar diretamente o endereço de uma página não pode liberar o acesso.
RN017 — Recuperação de senha	A recuperação deve usar o e-mail cadastrado e um recurso temporário. A proposta é que esse recurso expire em 30 minutos e não possa ser usado novamente depois da troca da senha.

Resumo dos comportamentos

Situação	Comportamento esperado
E-mail ou senha incorretos	Negar o acesso e apresentar uma mensagem genérica.
Cinco tentativas incorretas seguidas	Bloquear temporariamente o acesso por 15 minutos.
Sessão sem atividade	Encerrar a sessão após 30 minutos.

Administrador seleciona sair	Encerrar a sessão.
Acesso a uma rota protegida sem login	Negar o acesso e direcionar para o login.
Link de recuperação expirado	Solicitar que o administrador inicie uma nova recuperação.

Ponto que precisa ser validado pela equipe

Os limites de cinco tentativas, 15 minutos de bloqueio e 30 minutos de inatividade são sugestões para a equipe discutir e aprovar. Não devem ser tratados como regras definitivas antes dessa aprovação. Além disso, a análise do código disponível não comprovou que esses comportamentos já estejam implementados.